

CLOUD SEC & IA

CLOUD INCIDENT RESPONSE



2

LISTA DE FIGURAS

Figura 1 - Ícone do AWS CloudTrail	6
Figura 2 - Ícone do AWS Config	8
Figura 3 - Ícone do Amazon CloudWatch	10
Figura 4 - Ícone do AWS Lambda	11
Figura 5 - Ícone do AWS Identity and Access Management (IAM)	13
Figura 6 - Ícone do Amazon GuardDuty	14
Figura 7 - Ícone do AWS Systems Manager	16
Figura 8 - Console da AWS	18
Figura 9 - Navegação para o AWS CloudTrail	18
Figura 10 - Serviço do AWS CloudTrail	18
Figura 11 - Criação de Trilha no AWS CloudTrail	19
Figura 12 - Acesso a trilha criada	19
Figura 13 - Edição de Eventos de gerenciamento	19
Figura 14 - Salvas as alterações em gerenciamento de eventos	20
Figura 15 - Histórico de Eventos do CloudTrails	20
Figura 16 - Eventos sendo registrados no CloudTrail	21
Figura 17 - Detalhes de um evento registrado no CloudTrail	21
Figura 18 - Console da AWS	22
Figura 19 - Acessar serviço AWS Config	22
Figura 20 - Configurar AWS Config	22
Figura 21 - Configurações do AWS Config	23
Figura 22 - Configuração de Regras do AWS Config	23
Figura 23 - Revisar configurações do AWS Config	24
Figura 24 - Acessar o Painel em AWS Config	24
Figura 25 - Status de compatibilidade do AWS Config	25
Figura 26 - Inventário de recursos do AWS Config	25
Figura 27 - Análise de inconformidade de recurso pelo AWS Config	26

SUMÁRIO

RESPOSTA A INCIDENTES.....	4
1 INTRODUÇÃO	4
2 SERVIÇOS.....	5
2.1 AWS CloudTrail	5
2.2 AWS Config	6
2.3 Amazon CloudWatch.....	8
2.4 AWS Lambda	10
2.5 AWS Identity and Access Management (IAM).....	11
2.6 Amazon GuardDuty	13
2.7 AWS Systems Manager	14
3 EXEMPLOS PRÁTICOS (HANDS-ON).....	17
3.1 Monitoração de Recursos AWS CloudTrail e Amazon CloudWatch.....	17
3.2 Monitoração da Configuração com AWS Config	21
4 DESAFIOS	26
4.1 AWS Identity and Access Management (IAM).....	27
4.2 Detecção de ameaças com Amazon GuardDuty	29
4.3 Reposta automatizada com AWS Systems Manager	31
REFERÊNCIAS.....	34

RESPOSTA A INCIDENTES

1 INTRODUÇÃO

O domínio de resposta a incidentes é de extrema importância na área da Segurança de Computação em Nuvem. Com o aumento do número de organizações que adotam a nuvem como parte fundamental de suas infraestruturas de TI, torna-se essencial estar preparado para lidar com possíveis incidentes de segurança que possam ocorrer nesse ambiente.

A computação em nuvem oferece muitos benefícios, como escalabilidade, flexibilidade e redução de custos. No entanto, também traz consigo desafios significativos relacionados à segurança. Os dados confidenciais e sensíveis das organizações são armazenados e processados em servidores remotos, acessíveis através da internet. Isso cria uma superfície expandida de ataque, aumentando o potencial de incidentes de segurança.

O domínio de Resposta a Incidentes tem como objetivo fornecer diretrizes e práticas recomendadas para identificar, responder e mitigar os incidentes de segurança que possam afetar os sistemas e os dados em ambientes de computação em nuvem. Ele visa garantir que as organizações estejam preparadas para lidar com essas situações e minimizar os danos causados por possíveis violações de segurança.

A resposta eficaz a incidentes é crucial para proteger os ativos da organização, manter a confiança dos clientes e atender aos requisitos regulatórios. Este domínio abrange uma série de tópicos, incluindo a criação de planos de resposta a incidentes, a implementação de controles de detecção e monitoramento, a análise forense de incidentes, a comunicação efetiva durante incidentes e a realização de exercícios de simulação para testar a eficácia dos processos de resposta.

A certificação AWS Security Specialty (SCS-C01) para o domínio 1 - resposta a incidentes capacita os profissionais a desenvolverem competências essenciais para lidar com incidentes de segurança em ambientes de computação em nuvem da Amazon Web Services (AWS). Ao se concentrar nesse domínio, os candidatos adquirem habilidades práticas para identificar e responder a incidentes de segurança, bem como para implementar medidas preventivas e corretivas efetivas.

Dessa maneira, o domínio de Resposta a Incidentes é fundamental para a segurança de computação em nuvem, pois oferece diretrizes e práticas recomendadas para lidar com incidentes de segurança, minimizando o impacto e garantindo a continuidade dos serviços em ambientes de nuvem. A certificação AWS Security Specialty (SCS-C01) valida as habilidades necessárias para esse domínio e demonstra o compromisso com a segurança dos dados e sistemas em um ambiente em constante evolução tecnológica.

2 SERVIÇOS

A AWS oferece uma ampla gama de serviços que podem ser utilizados para tratar o Domínio 1: Resposta a Incidentes de forma detalhada. Abaixo estão alguns dos principais serviços da AWS que podem ser empregados nesse contexto, juntamente com seus casos de uso típicos:

2.1 AWS CloudTrail

- **Descrição:** O AWS CloudTrail é um serviço da AWS que permite o monitoramento e o registro de todas as atividades realizadas em uma conta da AWS. Ele fornece informações detalhadas sobre ações de usuário, eventos de API, alterações em recursos e muito mais. O CloudTrail captura e registra esses dados em logs, permitindo que os usuários revisem e auditem atividades em sua infraestrutura na nuvem. O CloudTrail oferece uma visibilidade abrangente do histórico de eventos na conta da AWS, ajudando na segurança, conformidade e solução de problemas. Ele permite rastrear e investigar ações específicas, identificar possíveis ameaças à segurança e detectar atividades maliciosas. Ao ativar o CloudTrail, os eventos capturados são armazenados em um bucket do Amazon S3 para posterior análise. Os logs gerados contêm informações como o horário da ação, o usuário ou recurso afetado e o endereço IP de origem. Esses logs podem ser consultados e pesquisados usando serviços como o Amazon Athena, facilitando a análise e a extração de informações úteis. Além disso, o CloudTrail pode ser configurado para enviar notificações em tempo real

para o Amazon CloudWatch, permitindo a detecção e a resposta imediata a eventos importantes. Os usuários também podem criar regras e alertas personalizados com base nos registros do CloudTrail para automatizar ações e melhorar a segurança da conta.

O AWS CloudTrail é amplamente utilizado para atender aos requisitos de conformidade e auditoria, como o GDPR. Ele fornece evidências e registros detalhados necessários para demonstrar a conformidade regulatória e a trilha de auditoria. Em resumo, o AWS CloudTrail é um serviço vital para o monitoramento e o registro de atividades em uma conta da AWS. Ele oferece uma visibilidade completa das ações realizadas, auxiliando na segurança, conformidade e solução de problemas. Com o CloudTrail, os usuários podem rastrear e investigar eventos, detectar atividades maliciosas e cumprir requisitos de auditoria e conformidade (GOLDFARB et al., 2021).

- **Caso de uso:** Com o CloudTrail, é possível monitorar e auditar ações realizadas em uma conta da AWS, facilitando a detecção e investigação de incidentes de segurança (GOLDFARB et al., 2021).

A figura “Ícone do AWS CloudTrail” representa o ícone padrão da própria AWS para este serviço.



Figura 1 - Ícone do AWS CloudTrail
Fonte: AWS (2023), adaptado por FIAP (2023)

2.2 AWS Config

- **Descrição:** O AWS Config é um serviço da AWS que fornece um inventário detalhado e histórico de configurações dos recursos da sua conta. Ele permite que você avalie, monitore e registre as mudanças em sua

infraestrutura e recursos ao longo do tempo. O AWS Config captura informações sobre configurações, relacionamentos e estados dos recursos, fornecendo uma visão abrangente e precisa do ambiente de nuvem. Ao habilitar o AWS Config, você pode definir regras de configuração personalizadas para avaliar continuamente a conformidade das configurações.

Isso permite identificar violações de conformidade, detectar mudanças não autorizadas e garantir que seus recursos estejam configurados de acordo com as melhores práticas recomendadas.

O AWS Config também fornece uma visão histórica das configurações, permitindo que você analise como elas evoluíram ao longo do tempo e investigue eventos específicos. O AWS Config registra todas as alterações nos recursos da sua conta em logs detalhados e armazena esses logs em um bucket do Amazon S3. Isso permite a análise e a auditoria retroativa das configurações e ajuda na identificação de causas raiz de problemas e na resolução de incidentes. Além disso, o AWS Config pode ser integrado com outros serviços da AWS, como o AWS CloudTrail e o Amazon CloudWatch. Essa integração permite correlacionar eventos de alterações de configuração com atividades de usuários, bem como criar alarmes e notificações personalizadas com base nas alterações detectadas. O AWS Config é útil para garantir a conformidade, identificar e corrigir desvios de configuração, bem como para melhorar a governança e a segurança da sua infraestrutura na nuvem. Ele fornece uma visão abrangente e em tempo real do estado das configurações e recursos, ajudando você a manter um ambiente seguro, confiável e em conformidade com as políticas estabelecidas. Em resumo, o AWS Config é um serviço essencial para o monitoramento contínuo das configurações dos recursos na sua conta da AWS. Ele fornece um inventário detalhado, histórico de configurações e ferramentas para avaliação de conformidade, permitindo identificar desvios, melhorar a governança e garantir a segurança do ambiente em nuvem (GOLDFARB et al., 2021).

- **Caso de uso:** O AWS Config pode ser utilizado para monitorar a configuração de recursos da AWS, identificar alterações não autorizadas e

ajudar na resposta a incidentes, permitindo a rápida restauração de configurações corretas (GOLDFARB et al., 2021).

A figura “Ícone do AWS Config” representa o ícone padrão da própria AWS para este serviço.

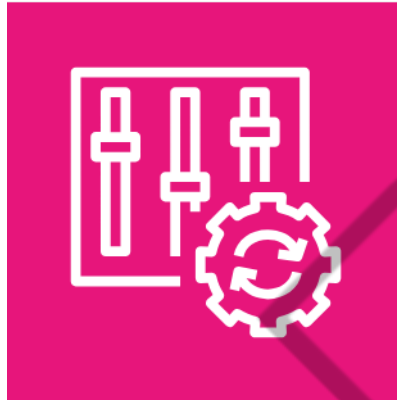


Figura 2 - Ícone do AWS Config
Fonte: AWS (2023) , adaptado por FIAP (2023)

2.3 Amazon CloudWatch

- **Descrição:** O Amazon CloudWatch é um serviço de monitoramento e observabilidade da AWS que permite coletar, armazenar e acessar métricas, logs e eventos de seus recursos e aplicativos na nuvem. Ele fornece uma visibilidade abrangente do desempenho operacional e da utilização dos recursos, permitindo a tomada de decisões informadas e a solução de problemas de forma eficiente. O CloudWatch oferece os seguintes recursos principais:
 - 1) **Métricas:** Você pode coletar e monitorar métricas em tempo real de recursos da AWS, como instâncias EC2, bancos de dados RDS, serviços do Amazon ECS, entre outros. As métricas incluem informações sobre a utilização de CPU, uso de memória, tráfego de rede e muito mais. Essas métricas são armazenadas no CloudWatch e podem ser usadas para criar gráficos, definir alarmes e realizar análises.
 - 2) **Logs:** O CloudWatch Logs permite coletar, monitorar e analisar logs de aplicativos e sistemas em um local centralizado. Você pode enviar logs de diferentes fontes, como instâncias EC2, grupos de contêineres do

Amazon ECS, servidores web do Elastic Load Balancer e outros serviços, para o CloudWatch Logs. Os logs podem ser filtrados, pesquisados e armazenados por um período definido. Eles também podem ser enviados para outras ferramentas de análise, como o Amazon Elasticsearch ou o Amazon S3, para uma análise mais avançada.

- 3) Eventos: O CloudWatch Events permite que você capture e responda a eventos de forma programática em sua infraestrutura. Ele funciona como um hub central para eventos gerados por diferentes serviços da AWS. Você pode configurar regras de eventos para acionar ações automatizadas em resposta a eventos específicos. Por exemplo, você pode iniciar uma instância EC2 sempre que um evento de aumento de carga for detectado.
- 4) Dashboards: O CloudWatch Dashboards permite criar painéis personalizados para visualizar as métricas e logs importantes para o seu ambiente. Você pode criar gráficos e widgets personalizados para monitorar o desempenho em tempo real e obter uma visão geral do status operacional dos seus recursos.
- 5) Alarmes: Com o CloudWatch Alarms, você pode definir alarmes com base em métricas para monitorar o desempenho e o estado dos recursos. Quando uma métrica ultrapassa um limite definido, um alarme é acionado e você pode receber notificações por e-mail, SMS ou enviar uma mensagem para um tópico do Amazon SNS. Os alarmes ajudam a identificar rapidamente problemas ou condições indesejadas e tomar ações corretivas.

O Amazon CloudWatch é uma ferramenta essencial para o monitoramento de recursos e aplicativos na AWS. Ele oferece insights valiosos sobre o desempenho operacional, ajuda na solução de problemas e permite tomar ações automatizadas com base em eventos. Com o CloudWatch, você pode garantir a alta disponibilidade, desempenho otimizado e segurança dos seus sistemas na nuvem (GOLDFARB et al., 2021).

- **Caso de uso:** O CloudWatch pode ser utilizado para detectar anomalias, configurar alertas e acionar respostas automatizadas a incidentes com base em métricas e eventos específicos (GOLDFARB et al., 2021).

A figura “Ícone do Amazon CloudWatch” representa o ícone padrão da própria AWS para este serviço.



Figura 3 - Ícone do Amazon CloudWatch
Fonte: AWS (2023) , adaptado por FIAP (2023)

2.4 AWS Lambda

- **Descrição:** O AWS Lambda é um serviço de computação sem servidor fornecido pela AWS. Ele permite que você execute seu código sem a necessidade de provisionar ou gerenciar servidores. O Lambda é projetado para ser altamente escalável, flexível e eficiente em termos de custo. Com o AWS Lambda, você pode escrever e executar funções em várias linguagens de programação, como Python, Node.js, Java, C# e muito mais. Você pode criar uma função Lambda para lidar com eventos específicos, como uma alteração em um bucket do Amazon S3, uma mensagem em uma fila do Amazon SQS ou uma chamada de API do Amazon API Gateway. O Lambda funciona com base no conceito de eventos e respostas a eventos. Quando ocorre um evento que você configurou para acionar a função Lambda, o serviço automaticamente executa sua função, fornecendo os dados de entrada necessários. O código da função é executado em um ambiente seguro e isolado, e você só paga pelo tempo de execução real do código, sem a necessidade de pagar por servidores em espera. O Lambda

também oferece recursos poderosos, como escala automática, onde o serviço gerencia automaticamente a alocação de recursos necessários para lidar com picos de carga. Ele também oferece integração com outros serviços da AWS, como o Amazon DynamoDB, Amazon S3, Amazon RDS e muitos mais. Em resumo, o AWS Lambda é um serviço sem servidor que permite que você execute código de forma escalável e eficiente em termos de custo.

Ele oferece uma maneira simples de executar suas funções em resposta a eventos, eliminando a necessidade de gerenciar a infraestrutura subjacente. O Lambda é uma ferramenta poderosa para criar aplicativos altamente responsivos e eficientes na nuvem (GOLDFARB et al., 2021).

- **Caso de uso:** O Lambda pode ser utilizado para automatizar ações de resposta a incidentes, como iniciar investigações, isolar recursos comprometidos e notificar equipes de segurança (GOLDFARB et al., 2021).

A figura “Ícone do AWS Lambda” representa o ícone padrão da própria AWS para este serviço.



Figura 4 - Ícone do AWS Lambda
Fonte: AWS (2023) , adaptado por FIAP (2023)

2.5 AWS Identity and Access Management (IAM)

- **Descrição:** O AWS Identity and Access Management (IAM) é um serviço de gerenciamento de identidade e acesso da AWS que permite controlar de forma centralizada o acesso aos recursos e serviços da AWS. Ele fornece recursos para criar e gerenciar usuários, grupos e funções, bem como definir permissões granulares para controlar o que os usuários podem fazer

dentro da sua conta. O IAM permite que você defina políticas de acesso que especificam as permissões necessárias para os usuários e recursos da sua conta. As políticas são baseadas no princípio do "princípio do menor privilégio", o que significa que os usuários têm apenas as permissões necessárias para realizar suas tarefas, garantindo a segurança e a redução de riscos. Com o IAM, você pode criar usuários e grupos e atribuir permissões a eles. Os usuários podem ser autenticados por meio de senhas ou por meio da integração com outros serviços de autenticação, como o AWS Single Sign-On (SSO) ou a autenticação federada.

Os grupos permitem agrupar usuários com permissões semelhantes para facilitar a administração. Além disso, as funções IAM permitem que você atribua permissões temporárias a usuários ou serviços. O IAM também oferece recursos avançados, como autenticação multifator (MFA), que adiciona uma camada extra de segurança ao exigir um segundo fator de autenticação além da senha. Você pode integrar o MFA aos usuários do IAM para garantir que somente usuários autorizados possam acessar recursos críticos. Outra característica importante do IAM é a capacidade de fazer auditoria e registrar eventos de atividades na sua conta. Você pode visualizar registros de eventos no AWS CloudTrail, o que permite rastrear e auditar ações tomadas por usuários e serviços. O IAM é fundamental para garantir a segurança e o gerenciamento adequado do acesso aos recursos da AWS. Ele permite que você defina permissões granulares, controle o acesso por usuário, grupo ou função, e mantenha um registro detalhado de atividades na sua conta. Com o IAM, você pode garantir que apenas usuários autorizados tenham acesso aos recursos e dados confidenciais, minimizando riscos de segurança e facilitando o gerenciamento de permissões (PIERCE et al., 2021).

- **Caso de uso:** O IAM pode ser utilizado para implementar uma política de privilégios mínimos, garantindo que apenas usuários autorizados tenham acesso a recursos críticos durante uma resposta a incidentes (PIERCE et al., 2021).

A figura “Ícone do AWS Identity and Access Management (IAM)” representa o ícone padrão da própria AWS para este serviço.



Figura 5 - Ícone do AWS Identity and Access Management (IAM)
Fonte: AWS (2023) , adaptado por FIAP (2023)

2.6 Amazon GuardDuty

- **Descrição:** O Amazon GuardDuty é um serviço de detecção de ameaças gerenciado pela AWS que oferece monitoramento contínuo e análise de atividades maliciosas e suspeitas em sua conta e cargas de trabalho na nuvem. Ele utiliza aprendizado de máquina e análise de dados para identificar possíveis ameaças de segurança, como ataques de força bruta, exploração de vulnerabilidades e atividades de botnets. O GuardDuty examina continuamente os dados de log de várias fontes, como o AWS CloudTrail, os logs de fluxo da VPC e os logs de DNS, para identificar padrões e comportamentos maliciosos. Ele também utiliza feeds de inteligência de ameaças da AWS e de terceiros para identificar atividades conhecidas de malwares e botnets. Ao detectar uma possível ameaça, o GuardDuty gera um alerta que inclui detalhes sobre a atividade suspeita, como o tipo de ameaça, o recurso afetado e as ações recomendadas. Você pode visualizar esses alertas no console do GuardDuty ou configurar notificações para receber os alertas por meio de serviços como o Amazon SNS ou o Amazon EventBridge. Além disso, o GuardDuty fornece uma visão geral dos níveis de gravidade das ameaças em sua conta, ajudando a priorizar as ações corretivas. Ele também oferece integração com outros serviços da AWS, como o AWS Security Hub e o AWS CloudWatch Events, para permitir uma resposta automatizada a eventos de segurança. O Amazon GuardDuty é altamente escalável e gerenciado pela AWS, o que

significa que você não precisa se preocupar com a infraestrutura subjacente ou as atualizações de software. Ele simplifica a detecção de ameaças e permite que você identifique e responda rapidamente a possíveis incidentes de segurança em sua infraestrutura na nuvem. Em resumo, o Amazon GuardDuty é um serviço de detecção de ameaças da AWS que fornece monitoramento contínuo e análise de atividades maliciosas em sua conta e cargas de trabalho na nuvem. Com sua capacidade de identificar ameaças conhecidas e desconhecidas, o GuardDuty ajuda a fortalecer a segurança de suas aplicações e dados na nuvem e permite uma resposta rápida a possíveis incidentes de segurança (PIERCE et al., 2021).

- **Caso de uso:** O GuardDuty pode ser utilizado para identificar atividades suspeitas ou comportamentos anormais, auxiliando na detecção e resposta a incidentes de segurança (PIERCE et al., 2021).

A figura “Ícone do Amazon GuardDuty representa o ícone padrão da própria AWS para este serviço.



Figura 6 – Ícone do Amazon GuardDuty
Fonte: AWS (2023) , adaptado por FIAP (2023)

2.7 AWS Systems Manager

- **Descrição:** O AWS Systems Manager é um serviço da AWS que oferece uma ampla gama de recursos para gerenciar e operar de forma centralizada recursos em ambientes de nuvem. Ele permite automatizar tarefas operacionais, simplificar o gerenciamento de recursos e aumentar a

eficiência operacional. O Systems Manager oferece os seguintes recursos principais:

- 1) Inventário e visibilidade: Com o Systems Manager, você pode coletar automaticamente informações detalhadas sobre os recursos em sua infraestrutura, como instâncias EC2, bancos de dados RDS e servidores do Amazon Elastic Container Service (ECS). Isso fornece uma visão abrangente dos recursos implantados em sua conta e ajuda a entender melhor o ambiente de nuvem.
- 2) Automação de tarefas: O Systems Manager permite automatizar tarefas comuns de gerenciamento, como aplicação de patches, instalação de software, configuração de segurança e execução de scripts personalizados.

Com o Automation Runbooks, você pode criar fluxos de trabalho personalizados para automatizar tarefas complexas e repetitivas, reduzindo o tempo gasto em atividades manuais.

- 3) Gerenciamento de patches: O Systems Manager facilita a aplicação de patches de segurança em instâncias EC2 e recursos do sistema operacional. Você pode criar políticas de patching personalizadas, agendar janelas de manutenção e automatizar a aplicação de patches em uma escala ampla.
 - 4) Configuração e conformidade: O Systems Manager permite gerenciar e monitorar a conformidade das configurações dos recursos em sua conta. Você pode definir políticas de configuração e usar o Resource Data Sync para coletar informações de configuração de várias contas e regiões em um único local centralizado.
 - 5) Monitoramento e coleta de logs: O Systems Manager integra-se ao Amazon CloudWatch para fornecer monitoramento centralizado e coleta de logs. Você pode visualizar métricas operacionais, como uso de CPU e memória, e coletar logs de instâncias EC2 em tempo real para análise e solução de problemas.
- Segurança e conformidade: O Systems Manager fornece recursos de segurança, como o Parameter Store para armazenar e gerenciar segredos e informações de configuração, e o

Session Manager para acesso seguro e auditable a instâncias EC2. Ele também oferece recursos de auditoria e conformidade para ajudar a atender aos requisitos regulatórios.

Em resumo, o AWS Systems Manager é uma ferramenta poderosa para gerenciar e operar recursos em ambientes de nuvem. Com seus recursos abrangentes, ele simplifica tarefas operacionais, automatiza processos, melhora a visibilidade e fortalece a segurança e a conformidade em sua infraestrutura na nuvem. O Systems Manager é essencial para manter a eficiência e a confiabilidade dos seus recursos na AWS (PIERCE et al., 2021).

- **Caso de uso:** O Systems Manager pode ser utilizado para automatizar ações de resposta a incidentes, como o bloqueio de instâncias comprometidas, a atualização de patches de segurança e a execução de scripts de remediação (PIERCE et al., 2021).

A figura “Ícone do do AWS Systems Manager” representa o ícone padrão da própria AWS para este serviço.



Figura 7 - Ícone do AWS Systems Manager
Fonte: AWS (2023) , adaptado por FIAP (2023)

Esses são apenas alguns exemplos dos serviços da AWS que podem ser utilizados para tratar o domínio 1 - resposta a incidentes. Cada serviço oferece recursos específicos que podem ser combinados e personalizados para atender às necessidades de resposta a incidentes de segurança em ambientes de computação

em nuvem. É importante ressaltar que a escolha dos serviços adequados dependerá das especificidades do ambiente e dos requisitos de segurança da organização.

3 EXEMPLOS PRÁTICOS (HANDS-ON)

Realizar estudos práticos hands-on desempenha um papel fundamental na assimilação dos conhecimentos em ambientes de nuvem, especialmente na AWS. Por meio da prática direta, os alunos podem aplicar os conceitos teóricos em situações reais, ganhando experiência prática na configuração e no gerenciamento de serviços em nuvem. Para aproveitar ao máximo essa experiência, **é necessário que o aluno possua sua própria conta AWS**. Isso permite que eles tenham total controle sobre seu ambiente de estudo, experimentem diferentes configurações e se familiarizem com a interface e as ferramentas da AWS.

No entanto, é importante ressaltar que o uso da AWS está sujeito a custos. Durante os estudos práticos, o aluno pode incorrer em despesas em sua conta AWS, que serão cobradas em seu cartão de crédito. Portanto, é imprescindível que o aluno esteja ciente desses custos potenciais e tome medidas para monitorar e controlar os gastos, estabelecendo limites e configurando alertas para evitar surpresas indesejadas na fatura do cartão de crédito.

3.1 Monitoração de Recursos AWS CloudTrail e Amazon CloudWatch

Aqui está um exemplo prático detalhado, passo a passo, usando o AWS CloudTrail relacionado ao Domínio 1: Resposta a Incidentes:

Passo 1: Configurar o AWS CloudTrail

1. Acesse o Console de Gerenciamento da AWS.

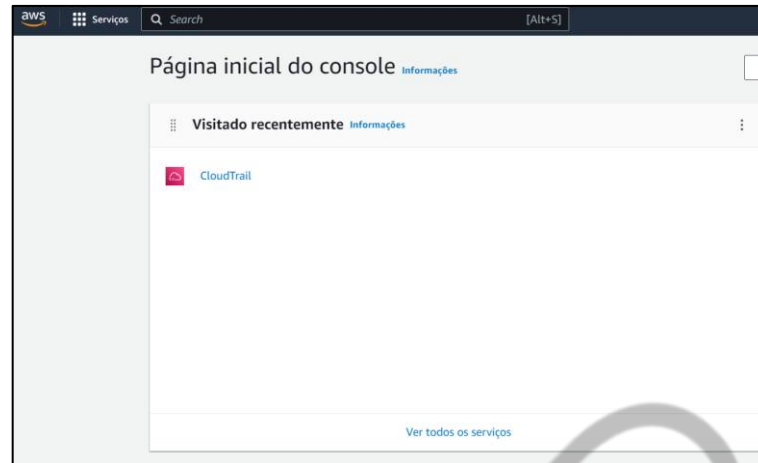


Figura 8 - Console da AWS
Fonte: Elaborador pelo autor (2023)

2. Navegue até o serviço AWS CloudTrail.

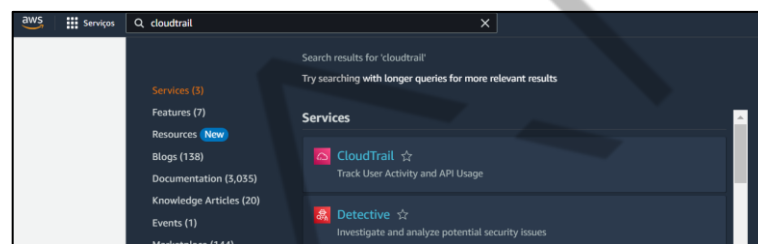


Figura 9 - Navegação para o AWS CloudTrail
Fonte: Elaborador pelo autor (2023)

3. Clique em "Criar trilha".



Figura 10 - Serviço do AWS CloudTrail
Fonte: Elaborador pelo autor (2023)

4. Insira um nome descritivo para a trilha, por exemplo, "Trilha-de-Auditoria", e selecione a opção "Criar uma nova trilha" na região "Leste dos EUA (Norte da Virgínia)".

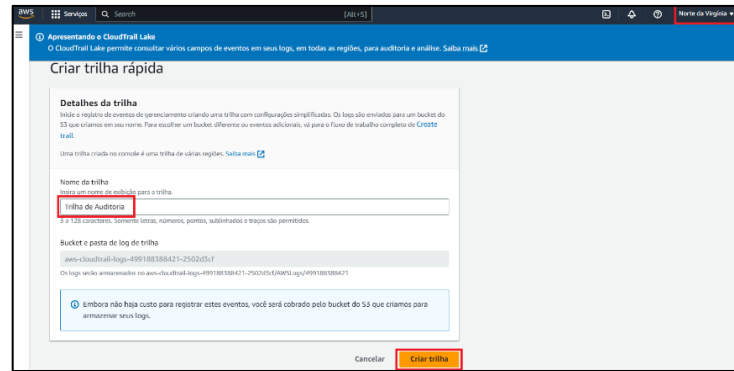


Figura 11 - Criação de Trilha no AWS CloudTrail
Fonte: Elaborador pelo autor (2023)

5. Acesse a trilha criada.

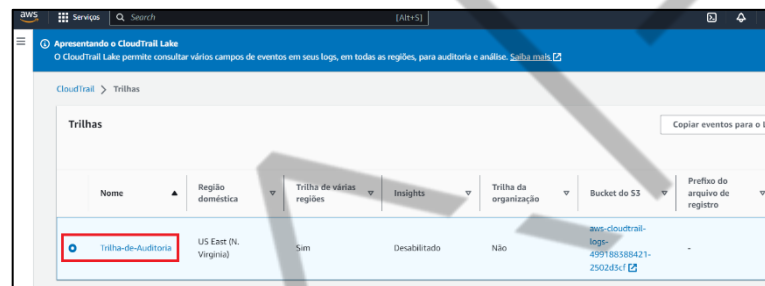


Figura 12 - Acesso a trilha criada
Fonte: Elaborador pelo autor (2023)

6. Clique no botão “Editar” da seção Eventos de gerenciamento.

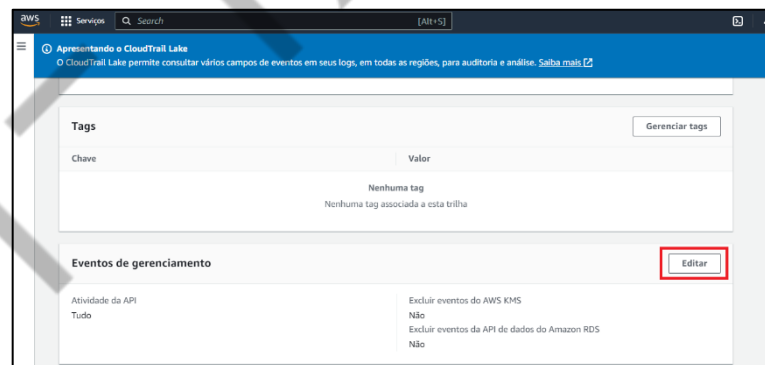


Figura 13 - Edição de Eventos de gerenciamento
Fonte: Elaborador pelo autor (2023)

7. Clique no botão “Salvar as alterações”.

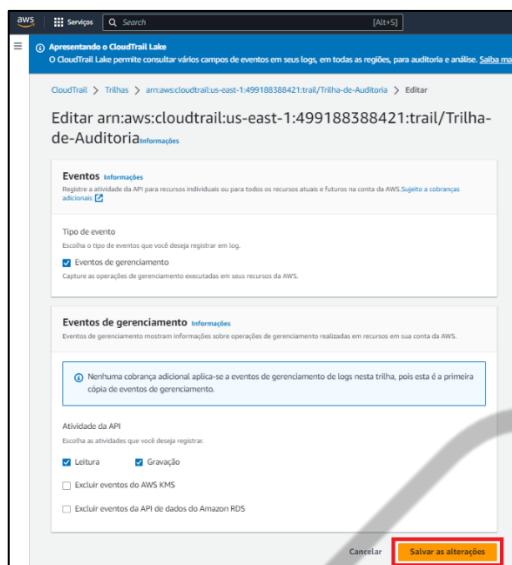


Figura 14 - Salvas as alterações em gerenciamento de eventos
Fonte: Elaborador pelo autor (2023)

Passo 2: Analisar os registros do AWS CloudTrail

1. Volte novamente na tela do CloudTrail e clique em Histórico de Eventos.

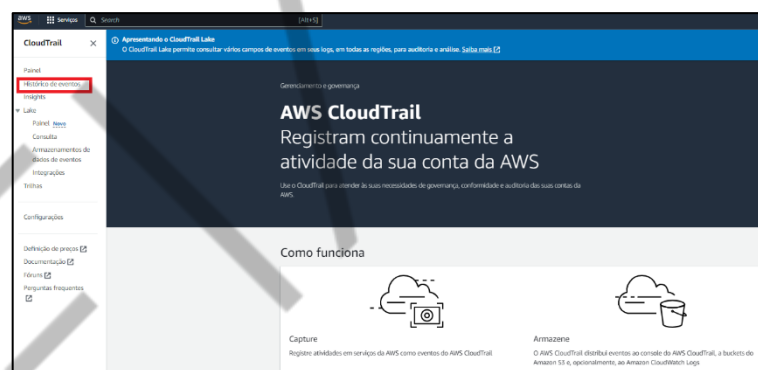


Figura 15 - Histórico de Eventos do CloudTrails
Fonte: Elaborador pelo autor (2023)

2. Aguarde alguns minutos para que os eventos sejam registrados na trilha do CloudTrail.

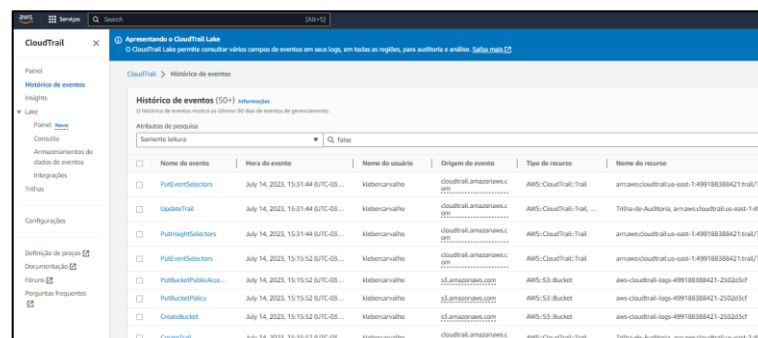


Figura 16 - Eventos sendo registrados no CloudTrail
Fonte: Elaborador pelo autor (2023)

3. Analise os eventos para identificar atividades suspeitas, como criação ou modificação de recursos, tentativas de acesso não autorizado, entre outras.

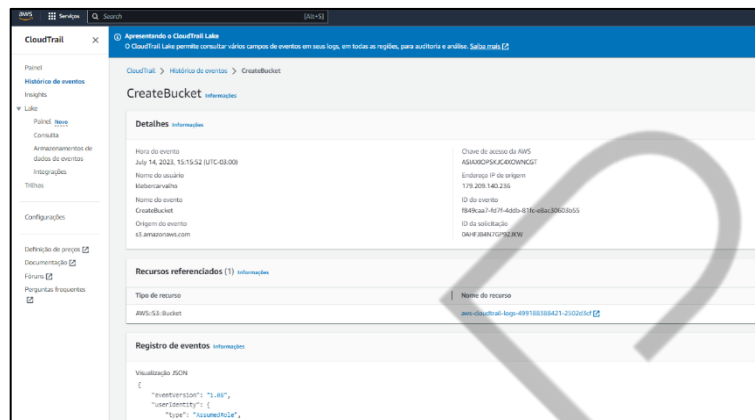


Figura 17 - Detalhes de um evento registrado no CloudTrail
Fonte: Elaborador pelo autor (2023)

Lembre-se de personalizar as configurações de acordo com as necessidades de sua organização e os eventos que você deseja monitorar. Esse exemplo fornece um ponto de partida para configurar o AWS CloudTrail e utilizar seus recursos de auditoria e detecção de incidentes.

3.2 Monitoração da Configuração com AWS Config

Aqui está um exemplo prático detalhado, passo a passo, usando o serviço AWS Config relacionado ao domínio 1- resposta a incidentes:

Passo 1: Configurar o AWS Config

1. Acesse o Console de Gerenciamento da AWS.

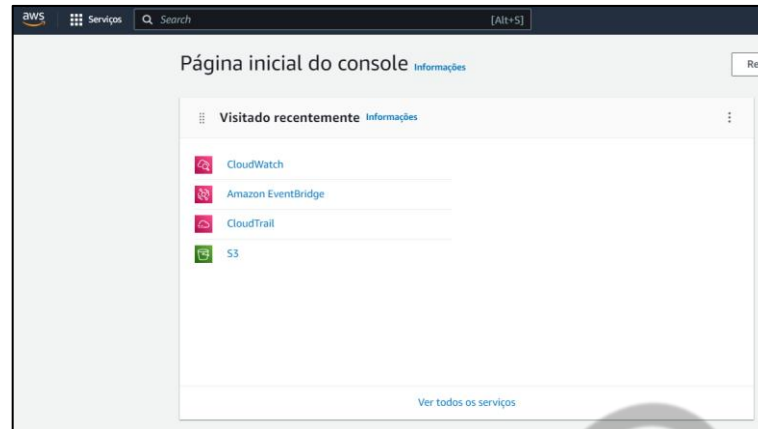


Figura 18 - Console da AWS
Fonte: Elaborador pelo autor (2023)

2. Navegue até o serviço AWS Config.

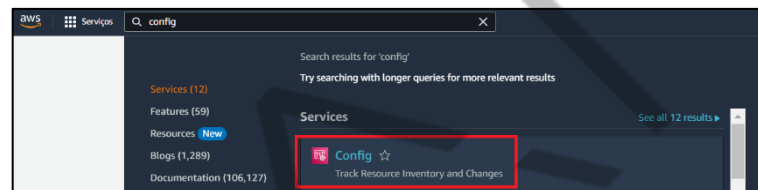


Figura 19 - Acessar serviço AWS Config
Fonte: Elaborador pelo autor (2023)

3. Clique em “Configurar AWS Config”, conforme a figura abaixo.

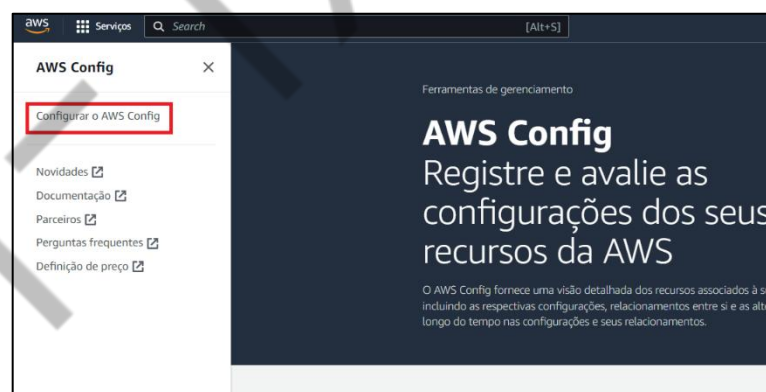


Figura 20 - Configurar AWS Config
Fonte: Elaborador pelo autor (2023)

4. Na etapa 1, escolha a opção “Record specific Resource types”, na categoria de recursos selecione AWS S3 Bucket, no método de entrega selecione “Criar um bucket” e deixe que a própria configuração especifique um “S3 bucket name”.

Configurações

Configurações gerais

Recording strategy

☐ Record all current and future resource types supported in this region

☐ Record all current and future resource types with exclusions

☒ Record specific resource types

If you select this option, AWS Config will record only the resource types that you specify. If you choose to stop recording for a resource type, the configuration items that were already recorded will remain unchanged.

[Saber mais](#)

Categoria de recurso

AWS resources

tipo de recurso

Multiple selected

Função do AWS Config

☒ Criar uma função vinculada ao serviço do AWS Config

☐ Selecionar uma função de sua conta

Método de entrega

Bucket do Amazon S3

☒ Criar um bucket

☐ Selecionar um bucket de sua conta

☐ Selecionar um bucket de outra conta

Configure-se se as permissões apropriadas estão definidas nesta política do bucket do S3. [Saber mais](#)

S3 Bucket name (required)

config-bucket-49918838421

Prefixo (opcional)

/AWSLogs/49918838421/Config/

us-east-1

Tópicos do Amazon SNS

☐ Transmissão de alterações feitas nas configurações e as notificações para um tópico do Amazon SNS.

Se você escolher o e-mail como endpoint de notificação para o tópico SNS, poderá obter um grande volume de e-mails. [Saber mais](#)

Cancelar **Próximo**

Figura 21 - Configurações do AWS Config
Fonte: Elaborador pelo autor (2023)

5. Na etapa 2, no campo Regras gerenciadas pela AWS, filtre por “bucket”, em seguida, escolha a opção s3-bucket-logging-enabled.

Regras

Regras gerenciadas pela AWS (154)

bucket X 14 matches

	Nome	Rótulos	Modo de avaliação	Descrição
☐	cloudfront-origin-access-identity-enabled	CloudFront, Origin Access Identity	DETECTIVE	Checks if CloudFront distribution with Amazon S3 Origin type has origin access identity configured. The rule is NON_COMPLIANT if the CloudFront distribution is backed by S3 and any origin type is not OAI configured, or the origin is not an S3 bucket.
☐	cloudtrail-enabled	CloudTrail, Periodic	DETECTIVE	Checks if an AWS CloudTrail trail is enabled in your AWS account. The rule is NON_COMPLIANT if a trail is not enabled. Optionally, the rule checks a specific S3 bucket, Amazon Simple Notification Service (Amazon SNS) topic, and CloudWatch log group.
☐	cloudtrail-s3-dataevents-enabled	S3, CloudTrail, Data Events, Event Selectors	DETECTIVE	Checks if at least one AWS CloudTrail trail is logging Amazon Simple Storage Service (Amazon S3) data events for all S3 buckets. The rule is NON_COMPLIANT if there are trails or if no trails record S3 data events.
☐	s3-bucket-default-lock-enabled	S3	DETECTIVE	Checks if the S3 bucket has lock enabled, by default. The rule is NON_COMPLIANT if the lock is not enabled.
☐	s3-bucket-level-public-access-prohibited	S3, Bucket, PublicAccess	DETECTIVE	Checks if S3 buckets are publicly accessible. The rule is NON_COMPLIANT if an S3 bucket is not listed in the excludedPublicBuckets parameter and bucket level settings are public.
☒	s3-bucket-logging-enabled	S3	DETECTIVE, PROACTIVE	Checks if logging is enabled for your S3 buckets. The rule is NON_COMPLIANT if logging is not enabled.

Figura 22 - Configuração de Regras do AWS Config
Fonte: Elaborador pelo autor (2023)

6. Na etapa Revisar, clique em “Confirmar”.

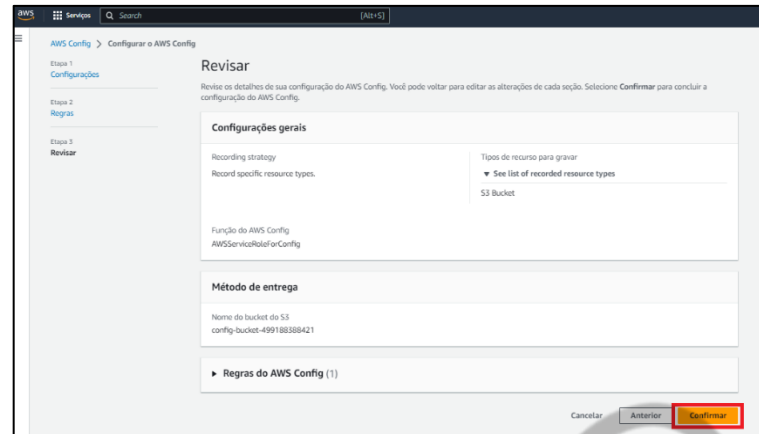


Figura 23 - Revisar configurações do AWS Config
Fonte: Elaborador pelo autor (2023)

Passo 2: Monitorar a conformidade de configuração

1. Aguarde a primeira execução da regra de configuração e navegue até o serviço AWS Config e acesse a seção de “Painel”, conforme a figura abaixo.

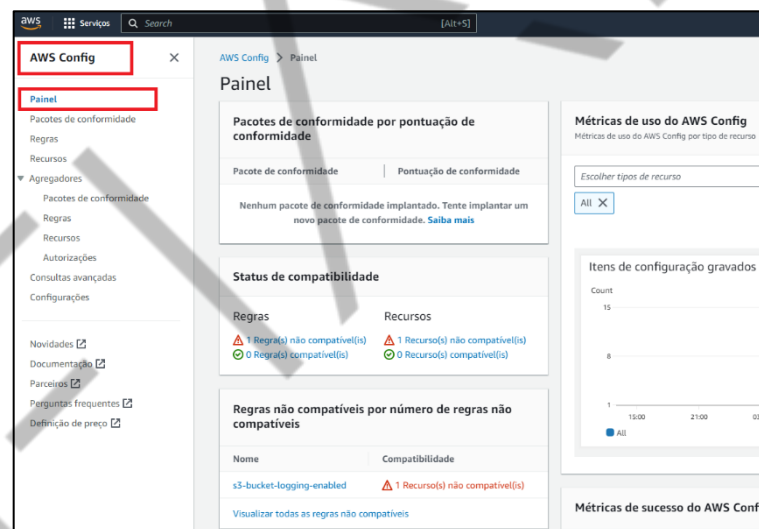
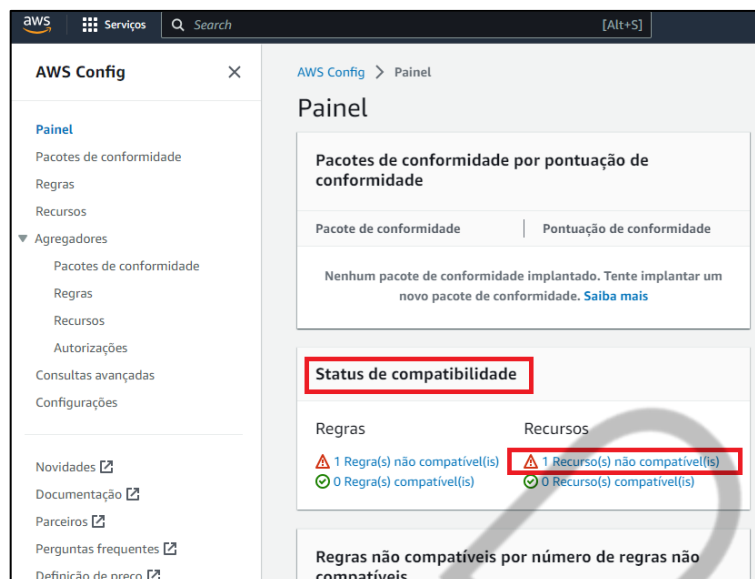


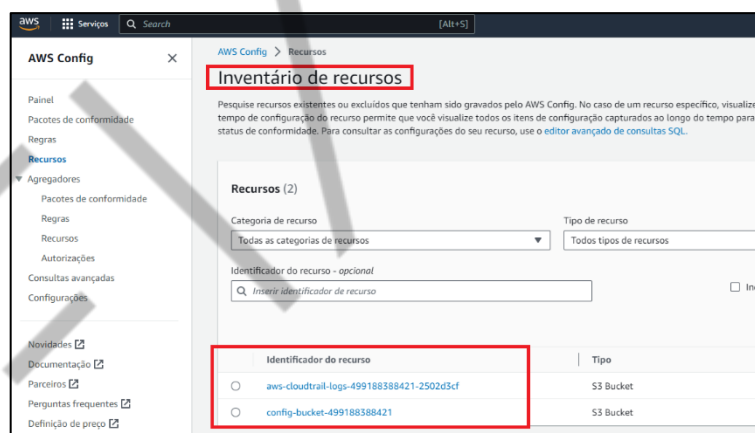
Figura 24 - Acessar o Painel em AWS Config
Fonte: Elaborador pelo autor (2023)

2. Caso exista algum recurso na conta que esteja incompatível com a regra de compatibilidade criada no Passo 1, aparecerá no Status de compatibilidade.



Fonte: Elaborador pelo autor (2023)

3. Clique sobre o recurso não compatível do item anterior para acessar o “Inventário de recursos” e obter a lista de “Identificador de recurso”.



Fonte: Elaborador pelo autor (2023)

4. Selecione qualquer recurso do “Identificar de recurso” para obter mais detalhes da inconformidade com a regra e, também, validar se essa inconformidade realmente está associada a regra criada no AWS Config.

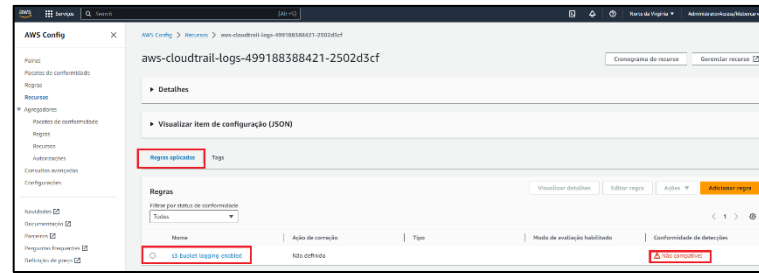


Figura 27 - Análise de inconformidade de recurso pelo AWS Config
Fonte: Elaborador pelo autor (2023)

Lembre-se de personalizar as configurações de acordo com as necessidades de sua organização e os requisitos de segurança. Esse exemplo demonstra como configurar o AWS Config para avaliar a conformidade de configurações em recursos selecionados e como monitorar e responder a não conformidades detectadas.

4 DESAFIOS

Realizar desafios práticos no estudo para a certificação AWS Security Specialty (SCS-C01) desempenha um papel fundamental na assimilação e compreensão dos conhecimentos necessários. Essa abordagem prática permite que você aplique os conceitos teóricos em situações reais, desenvolvendo habilidades práticas e aumentando sua confiança na resolução de problemas relacionados à segurança em ambientes de nuvem.

Os desafios práticos envolvem a realização de tarefas e cenários simulados, nos quais você terá a oportunidade de lidar com situações de segurança em tempo real. Esses desafios geralmente são baseados em casos de uso reais e abrangem vários aspectos do domínio de segurança da AWS, como resposta a incidentes, registro de logs, gerenciamento de identidade e acesso, entre outros.

Ao realizar desafios práticos, você terá a oportunidade de colocar em prática os conceitos aprendidos, ganhando experiência prática com os serviços e recursos da AWS. Isso ajuda a consolidar seu conhecimento teórico, pois você enfrentará desafios específicos que exigem a aplicação dos princípios de segurança em ambientes de nuvem.

Além disso, os desafios práticos proporcionam um ambiente de aprendizado interativo, onde você pode experimentar diferentes configurações, testar cenários e

explorar soluções para problemas complexos. Isso promove o pensamento crítico e a capacidade de resolver problemas de segurança em tempo real.

É importante ressaltar que realizar desafios práticos requer uma conta AWS ativa e a disposição para investir tempo e recursos. Esses desafios podem envolver a criação de recursos, a configuração de serviços e até mesmo a simulação de ataques e incidentes de segurança. Portanto, é essencial ter uma compreensão clara das implicações financeiras e garantir que você esteja ciente dos custos potenciais associados ao uso dos serviços AWS durante esses desafios práticos.

Os desafios práticos oferecem uma maneira eficaz de aprimorar seus conhecimentos em segurança na nuvem, permitindo que você ganhe confiança e desenvolva habilidades práticas essenciais para enfrentar os desafios da segurança em ambientes de nuvem. Ao aplicar os conceitos em situações reais, você estará preparado para lidar com os desafios complexos que podem surgir na implantação e gerenciamento de infraestruturas de nuvem seguras na AWS.

4.1 AWS Identity and Access Management (IAM)

Aqui está um exemplo prático detalhado, passo a passo, usando o serviço AWS Identity and Access Management (IAM) relacionado ao Domínio 1: Resposta a Incidentes:

Passo 1: Configurar políticas de acesso do IAM

1. Acesse o Console de Gerenciamento da AWS.
2. Navegue até o serviço AWS IAM.
3. Clique em "Políticas".
4. Clique em "Criar política".
5. Escolha entre criar uma política em branco ou usar um assistente de criação.

Para este exemplo, vamos criar uma política em branco.

6. Selecione o serviço ou ação que deseja controlar, como o AWS CloudTrail ou a criação de grupos de segurança.

7. Defina as permissões apropriadas para a ação, como permissões de leitura, gravação ou execução.

8. Clique em "Revisar política" e insira um nome descritivo para a política, por exemplo, "Política de Resposta a Incidentes".

9. Adicione uma descrição opcional para a política.

10. Clique em "Criar política" para criar a política de acesso do IAM.

Passo 2: Criar grupos de usuários

1. Navegue até o serviço AWS IAM.

2. Clique em "Grupos".

3. Clique em "Criar grupo".

4. Insira um nome descritivo para o grupo, como "Equipe de Segurança".

5. Clique em "Próxima etapa" e selecione as políticas que você deseja associar ao grupo.

6. Escolha as políticas que você criou na etapa anterior, relacionadas à resposta a incidentes.

7. Clique em "Revisar" e, em seguida, em "Criar grupo" para criar o grupo de usuários.

Passo 3: Adicionar usuários ao grupo

1. Navegue até o serviço AWS IAM.

2. Clique em "Usuários".

3. Clique em "Adicionar usuário".

4. Insira um nome de usuário para o novo usuário.

5. Selecione a opção "Acesso programático" se desejar que o usuário tenha acesso às APIs da AWS.

6. Escolha a opção "Atribuir diretamente ao grupo" e selecione o grupo de usuários criado na etapa anterior.

7. Clique em "Próxima etapa" e configure as permissões adicionais, como anexar uma política existente ou criar uma nova política para o usuário.

8. Revise as configurações e clique em "Criar usuário" para criar o usuário e adicioná-lo ao grupo.

Passo 4: Testar a autenticação e autorização

1. Forneça as credenciais do usuário que você criou na etapa anterior para realizar a autenticação.
2. Verifique se o usuário possui as permissões adequadas para realizar ações relacionadas à resposta a incidentes.
3. Tente executar ações que requerem permissões específicas, como acessar logs do CloudTrail, modificar configurações de segurança ou executar ações de resposta a incidentes.
4. Garanta que o usuário esteja restrito apenas às permissões necessárias para realizar suas funções de resposta a incidentes.

Lembre-se de personalizar as políticas de acesso, grupos de usuários e configurações de usuário de acordo com as necessidades e requisitos específicos de resposta a incidentes da sua organização. O IAM permite controlar o acesso e as permissões de forma granular para garantir a segurança dos recursos da AWS durante a resposta a incidentes.

4.2 Detecção de ameaças com Amazon GuardDuty

Aqui está um exemplo prático detalhado, passo a passo, usando o serviço Amazon GuardDuty relacionado ao Domínio 1: Resposta a Incidentes:

Passo 1: Configurar o Amazon GuardDuty

1. Acesse o Console de Gerenciamento da AWS.
2. Navegue até o serviço Amazon GuardDuty.
3. Clique em "Ativar GuardDuty".
4. Na página de ativação, selecione a região da AWS em que deseja ativar o GuardDuty.
5. Clique em "Continuar" e aguarde a ativação do serviço.

Passo 2: Analisar os resultados do Amazon GuardDuty

1. Navegue até o serviço Amazon GuardDuty.

2. Na página inicial, você verá uma visão geral dos eventos de segurança detectados.

3. Clique em "Detecções" para obter detalhes sobre os eventos identificados pelo GuardDuty.

4. Analise as detecções de segurança, como atividades suspeitas de acesso não autorizado, comportamentos anômalos ou tentativas de exploração.

5. Classifique e filtre as detecções para priorizar as mais relevantes para a resposta a incidentes.

Passo 3: Configurar alertas do Amazon GuardDuty

1. Navegue até o serviço Amazon GuardDuty.

2. Clique em "Configurações".

3. Em "Alertas", clique em "Criar um novo alerta".

4. Escolha o tipo de alerta que você deseja configurar, como "Acesso não autorizado" ou "Comunicação de comando e controle".

5. Defina os critérios de filtragem, como o nível de gravidade, região da AWS ou tipo de recurso.

6. Escolha a ação a ser tomada quando um alerta correspondente for acionado, como enviar uma notificação por e-mail ou acionar uma função do AWS Lambda.

7. Clique em "Criar alerta" para configurar o alerta.

Passo 4: Responder a incidentes com base nas detecções

1. Analise as detecções do Amazon GuardDuty para identificar eventos de segurança relevantes.

2. Siga os procedimentos de resposta a incidentes estabelecidos pela sua organização para lidar com as detecções.

3. Isso pode incluir ações como isolar recursos comprometidos, coletar evidências, notificar a equipe de segurança, entre outras medidas.

4. Utilize as informações fornecidas pelo GuardDuty para investigar e mitigar os incidentes de segurança detectados.

Lembre-se de personalizar as configurações de acordo com as necessidades e requisitos de segurança da sua organização. O Amazon GuardDuty é uma ferramenta poderosa para detectar atividades maliciosas e suspeitas na sua infraestrutura da AWS, permitindo uma resposta eficaz a incidentes de segurança.

Aqui está um exemplo prático detalhado, passo a passo, usando o serviço AWS Systems Manager relacionado ao Domínio 1: Resposta a Incidentes:

4.3 Reposta automatizada com AWS Systems Manager

Aqui está um exemplo prático detalhado, passo a passo, usando o serviço AWS Systems Manager relacionado ao Domínio 1: Resposta a Incidentes:

Passo 1: Configurar o AWS Systems Manager

1. Acesse o Console de Gerenciamento da AWS.
2. Navegue até o serviço AWS Systems Manager.
3. Clique em "Iniciar Sessão no Systems Manager".
4. No painel de navegação à esquerda, escolha a categoria de recursos desejada, como "Gerenciador de Patches", "Inventário" ou "Automação".
5. Clique em "Configurar" para configurar o recurso escolhido.

Passo 2: Utilizar o AWS Systems Manager para resposta a incidentes

Opção A: Gerenciador de Patches

1. No painel de navegação do AWS Systems Manager, clique em "Gerenciador de Patches".
2. Clique em "Criar associação".
3. Selecione a opção "Criar uma nova associação" e escolha os recursos que você deseja aplicar patches, como instâncias EC2.
4. Especifique os critérios de seleção de instâncias, como tags, grupos de segurança ou IDs de instância.
5. Configure a programação de aplicação de patches e defina o cronograma adequado para seu ambiente.

6. Escolha as atualizações de patches a serem aplicadas e as configurações adicionais, como ações de reinicialização.

7. Clique em "Criar associação" para criar a associação de patch.

Opção B: Inventário

1. No painel de navegação do AWS Systems Manager, clique em "Inventário".

2. Clique em "Criar associação".

3. Selecione a opção "Criar uma nova associação" e escolha os recursos que você deseja coletar inventário, como instâncias EC2.

4. Especifique os critérios de seleção de instâncias, como tags, grupos de segurança ou IDs de instância.

5. Configure a frequência de coleta de inventário e defina os dados específicos que você deseja coletar, como informações de software ou configurações de segurança.

6. Clique em "Criar associação" para criar a associação de inventário.

Opção C: Automação

1. No painel de navegação do AWS Systems Manager, clique em "Automação".

2. Clique em "Executar automação".

3. Selecione a automação relevante para a resposta a incidentes que você deseja executar, como "Responder a um alerta de segurança" ou "Isolar um recurso comprometido".

4. Configure os parâmetros necessários para a automação, como o ID da instância ou o nome do bucket do Amazon S3.

5. Clique em "Executar" para iniciar a automação.

Passo 3: Monitorar e responder a incidentes

1. Utilize os recursos do AWS Systems Manager, como o Gerenciador de Patches, Inventário e Automação, para monitorar e responder a incidentes em seu ambiente.

2. Analise os resultados de patches aplicados, inventários coletados e automações executadas para identificar problemas de segurança ou conformidade.

3. Tome as medidas apropriadas de resposta a incidentes com base nas informações fornecidas pelo AWS Systems Manager.

Lembre-se de personalizar as configurações e as opções de resposta a incidentes de acordo com as necessidades e requisitos específicos de segurança da sua organização. O AWS Systems Manager oferece uma ampla gama de recursos para ajudar na resposta a incidentes e no gerenciamento de recursos da AWS.

EMANIP

REFERÊNCIAS

AWS. **AWS Architecture Icons**. 2023. Disponível em: <https://aws.amazon.com/pt/architecture/icons/>. Acesso em: 14 jul. 2023.

GOLDFARB, Dario et al. **AWS Certified Security Study Guide: Specialty (scs-c01) Exam**. Estados Unidos: Sybex, 2021.

PIERCE, Tracy et al. **AWS Certified Security Specialty Exam Guide: Exam scs-c01**. Estados Unidos: McGraw Hill, 2021.

EMANIP